Identité numérique & preuve électronique

BTS SIO 1ère année

Protéger le nom de l'organisation, prouver l'intégrité d'un document

Identité numérique & preuve électronique

Objectifs

- Caractériser l'identité numérique d'une organisation et recenser ses sources de présence en ligne.
- Identifier les menaces qui pèsent sur cette identité et leur opposer une mesure.
- Vérifier l'intégrité d'un fichier à partir de son empreinte.
- Expliquer ce qu'une signature électronique apporte de plus.

Prérequis

- DICP : disponibilité, intégrité, confidentialité, preuve (séquence 1).
- Données à caractère personnel et RGPD (séquence 2).

Sommaire

Partie	Contenu
Partie 1	L'identité numérique d'une organisation
Partie 2	Quand on se fait passer pour vous
Partie 3	Prouver qu'un fichier n'a pas changé
Partie 4	Vérifier un devis, signer un document

> **Repère**
>
> Compétence **B3.2 — Préserver l'identité numérique de l'organisation**. Les parties 1 et 2 couvrent « protéger l'identité numérique d'une organisation » ; les parties 3 et 4 couvrent « déployer les moyens appropriés de preuve électronique ».

Le fil de la séquence

Un client de Soft-Tech reçoit une facture par courriel : en-tête Soft-Tech, logo correct, signature au nom de la responsable, et un RIB. Il paie. Soft-Tech n'a jamais envoyé cette facture.

Trois questions traversent la séquence :

1. Qu'est-ce qui a été attaqué, alors qu'aucun ordinateur de Soft-Tech n'a été piraté ?
2. Le client aurait-il pu s'en rendre compte ?
3. Comment Soft-Tech peut-elle prouver que cette facture n'est pas la sienne ?

Partie 1 — L'identité numérique d'une organisation

L'**identité numérique d'une organisation** est l'ensemble des éléments par lesquels elle est reconnue en ligne : son nom, son nom de domaine, ses adresses de courriel, ses comptes, ses publications, et les traces qui s'y rattachent.

Ce n'est pas un compte unique. Une organisation a des **identités multiples**, chacune avec ses données associées.

Trois notions à ne pas confondre

	De quoi on parle	Exemple
Identité numérique **de l'organisation**	Ce par quoi l'entreprise est reconnue en ligne	Le domaine `soft-tech.fr`
Identité numérique **d'une personne**	Ce par quoi un individu est reconnu	Le compte personnel de la responsable
E-réputation	Ce que les autres disent de l'organisation	Les avis clients, les commentaires

Une organisation peut avoir une identité numérique bien protégée et une mauvaise e-réputation : ce sont deux sujets distincts.

Les sources de la présence en ligne

- Le **nom de domaine** et les adresses de courriel qui en dépendent.
- Le **site web** institutionnel et les applications web.
- Les **applications mobiles** publiées au nom de l'organisation.
- Les **réseaux sociaux** et les traces qui s'y accumulent.
- Les **messageries instantanées** professionnelles.

> **À retenir**
>
> Recenser ces sources, c'est aussi désigner **qui en a la clé**. Une source sans propriétaire identifié est une source que personne ne surveille — et c'est par là que l'usurpation passe.

Exercice

Pour chacun, dire s'il relève de l'identité numérique de l'organisation, de l'e-réputation, ou d'aucune des deux : le domaine `soft-tech.fr` ; un avis client trois étoiles ; l'adresse `contact@soft-tech.fr` ; le compte personnel de la responsable sur un réseau social ; la page « Nos services » du site.

Partie 2 — Quand on se fait passer pour vous

Une **usurpation d'identité** ne suppose aucun piratage : il suffit d'imiter de façon crédible. Ce qui est exploité, ce n'est pas une faille technique, c'est la **confiance** attachée à un nom.

Les indices d'un courriel frauduleux

- Le **domaine de l'expéditeur** : un domaine qui *ressemble* n'est pas le même domaine. N'importe qui peut acheter un nom approchant.
- Une **adresse de réponse** différente de l'adresse d'expédition.
- L'**urgence** et la menace : elles servent à empêcher la vérification.
- Un **changement de coordonnées bancaires** annoncé par courriel : c'est le motif classique de la fraude au virement.
- Un **horaire d'envoi** ou une formulation qui ne correspondent pas à l'organisation.

Menaces et mesures de protection

Menace	Ce que c'est	Une mesure
Hameçonnage	Imiter une organisation de confiance pour obtenir un paiement ou un mot de passe	SPF, DKIM, DMARC sur le domaine
Défacement	Modifier l'apparence ou le contenu du site public	Mise à jour et sauvegarde du site
Fausse application mobile	Publier une application au nom de l'organisation	Veille sur l'usage du nom
Ingénierie sociale	Manipuler une personne plutôt qu'un système	Authentification forte, procédure de vérification

> **À retenir**
>
> **SPF, DKIM et DMARC** sont trois réglages publiés sur le nom de domaine. Ils permettent au serveur qui **reçoit** un message de vérifier qu'il a bien été envoyé par un serveur autorisé pour ce domaine. On retient ce qu'ils vérifient ; leur configuration n'est pas au programme de première année.

Partie 3 — Prouver qu'un fichier n'a pas changé

Un programme lit un fichier **entier** et en calcule une suite de caractères de **longueur fixe** : son **empreinte** (aussi appelée *condensat*, ou *hash*). Un fichier de 2 Ko et un fichier de 2 Go donnent une empreinte de même longueur.

Trois propriétés

1. **Déterministe** — le même fichier donne toujours la même empreinte, sur n'importe quelle machine et à n'importe quel moment.
2. **À sens unique** — on ne remonte pas au fichier depuis son empreinte : l'information n'est pas cachée, elle est perdue.
3. **Sensible** — la moindre modification change l'empreinte **en entier**, pas seulement en partie.

```
Devis : 340,00 EUR   →  e3f1a7c9...b204
Devis : 940,00 EUR   →  7b52d0e4...c81f
```

> **Attention**
>
> Une empreinte n'est **pas** un chiffrement. Un fichier chiffré se déchiffre : l'information est là, protégée par une clé. Une empreinte ne se « déchiffre » pas — il n'y a rien à retrouver, et aucune clé n'intervient. Publier l'empreinte d'un devis ne révèle rien de son contenu, mais ne le protège pas non plus.

Comment on s'en sert

L'émetteur calcule l'empreinte du document et la **publie à part** (sur son site, ou de vive voix). Le destinataire recalcule l'empreinte de son côté et compare. Identiques : le fichier reçu est exactement celui qui a été envoyé. Différentes : il a changé.

Ce qu'une empreinte ne prouve pas

Si le document **et** son empreinte arrivent par le même canal, celui qui modifie le fichier peut recalculer l'empreinte et remplacer les deux : la vérification passera sans rien signaler.

> **À retenir**
>
> Une empreinte prouve l'**intégrité** par rapport à une référence — à condition que cette référence ait voyagé autrement. Elle ne dit rien de l'**origine** du document.

Exercice

Vrai ou faux, en justifiant : deux fichiers différents peuvent avoir la même empreinte ; à partir de l'empreinte d'un devis on peut retrouver son montant ; si l'empreinte calculée correspond à l'empreinte publiée le fichier est intact ; une empreinte prouve qui a envoyé le fichier.

Partie 4 — Vérifier un devis, signer un document

Calculer une empreinte

```
sha256sum devis-2026-0912-a.pdf
sha256sum devis-2026-0912-a.pdf devis-2026-0912-b.pdf
```

`sha256sum` fait partie des outils de base du système, aucune installation n'est nécessaire. Pour comparer deux empreintes, inutile de lire les 64 caractères : vérifier les premiers et les derniers suffit.

La signature électronique

Une **signature électronique** lie un document à celui qui l'a émis, grâce à un secret que lui seul détient. Si la vérification réussit, le document n'a pas changé **et** il vient bien de cet émetteur : les deux garanties d'un seul geste.

	Ce que ça prouve
Empreinte seule	Le document n'a pas changé, par rapport à une référence fiable
Signature	Le document n'a pas changé **et** il vient bien de cet émetteur

> **À retenir**
>
> Si Soft-Tech avait signé électroniquement ses factures, le client aurait pu vérifier la signature avant de payer : la fausse facture n'en aurait eu aucune de valide, l'escroc ne détenant pas le secret de Soft-Tech.

Ce qui reste à voir. Nous avons décrit un principe et manipulé un outil de hachage. Comment une signature est fabriquée et vérifiée — clés, certificats, autorités de certification — relève de la deuxième année.

Corrigés

BTS SIO 1ère année

Protéger le nom de l'organisation, prouver l'intégrité d'un document

Identité numérique & preuve électronique

Partie 1 — Exercice

Élément	Réponse
Le domaine `soft-tech.fr`	Identité numérique de l'organisation
Un avis client trois étoiles	E-réputation
`contact@soft-tech.fr`	Identité numérique de l'organisation
Le compte personnel de la responsable	Aucune des deux — identité numérique d'une personne
La page « Nos services »	Identité numérique de l'organisation

Le quatrième cas est le plus discuté : le compte est bien une identité numérique, mais celle d'un **individu**. Le référentiel insiste sur la distinction.

Partie 2 — Le courriel frauduleux

Neuf indices étaient présents dans le message. Cinq suffisaient ; celui sur le domaine était attendu de tous.

Ce qu'on repère	Pourquoi c'est un indice
Domaine `soft-tech-facturation.fr`	Ce n'est **pas** `soft-tech.fr`. Un domaine qui ressemble n'est pas le même : n'importe qui peut acheter un nom approchant. **L'indice décisif.**
Adresse de réponse différente	La réponse partirait vers `mail-pro.net`, un troisième domaine sans rapport
Objet en majuscules, « RÈGLEMENT IMMÉDIAT REQUIS »	Une entreprise réelle n'écrit pas ses objets de facture ainsi
Envoi un samedi à 22h47	Le service comptabilité d'une TPE n'émet pas de facture à cette heure
Changement de coordonnées bancaires annoncé par courriel	Le motif classique de la fraude au virement : c'est **le but** du message
Délai de 48 h, majoration, matériel non restitué	L'urgence et la menace servent à empêcher la vérification
Absence totale d'accents	Indice faible seul, révélateur avec le reste
Aucune référence à une intervention précise	Le vrai atelier saurait quel matériel a été réparé, et quand

Le point essentiel : aucun système informatique de Soft-Tech n'a été attaqué. Ce qui a été exploité, c'est la **confiance attachée à son nom**. Un pare-feu n'y aurait rien changé.

Menaces et mesures

Menace	Ce que c'est	Mesure attendue
Hameçonnage	Un message imite une organisation de confiance pour obtenir un paiement ou un mot de passe	**SPF, DKIM, DMARC** : le serveur destinataire vérifie que le message vient bien du domaine annoncé
Défacement	Un attaquant modifie l'apparence ou le contenu du site public	**Mise à jour et sauvegarde** : corriger la faille, restaurer une version saine
Fausse application mobile	Une application publiée au nom de l'organisation, qu'elle n'a pas produite	**Veille** sur l'usage du nom : on ne retire que ce qu'on a repéré
Ingénierie sociale	Manipuler une personne plutôt qu'un système	**Authentification forte** et procédure de vérification

Plusieurs associations se défendent : c'est la **justification** qui compte, pas la correspondance exacte avec ce tableau.

Partie 3 — Exercice

1. **Vrai**, en théorie : deux fichiers différents peuvent donner la même empreinte, c'est une *collision*. Avec les algorithmes utilisés aujourd'hui, c'est si improbable qu'on raisonne comme si cela n'arrivait pas. Répondre « faux » en expliquant que c'est négligeable en pratique est accepté ; répondre « faux » sans explication ne l'est pas.
2. **Faux.** L'empreinte est à sens unique : l'information du document est perdue, pas cachée.
3. **Vrai**, à une condition : que l'empreinte publiée soit fiable, c'est-à-dire qu'elle provienne d'un canal que l'attaquant ne contrôle pas.
4. **Faux.** L'empreinte prouve l'intégrité, pas l'origine. N'importe qui peut calculer une empreinte ; c'est la signature qui atteste de l'émetteur.

Partie 4 — Vérification des devis

Le fichier authentique est `devis-2026-0912-a.pdf` : son empreinte correspond à celle publiée par Soft-Tech. Celle de `devis-2026-0912-b.pdf` n'y correspond pas.

La différence porte sur le **total TTC** : **340,00 €** dans le fichier authentique, **940,00 €** dans le fichier altéré. Tout le reste est identique — les lignes de prestation, le total HT (283,33 €) et la TVA (56,67 €) n'ont pas été touchés.

> **Le détail à remarquer.** Dans le fichier altéré, le total TTC ne correspond plus à la somme du total HT et de la TVA. On pouvait s'en apercevoir **sans outil** — mais il fallait refaire le calcul. L'empreinte, elle, signale la modification immédiatement, sans dépendre de la vigilance du lecteur.

La **quasi-totalité** des caractères de l'empreinte diffère entre les deux fichiers : un seul chiffre modifié suffit. Il n'existe pas d'empreinte « presque identique ».

Ce que la signature ajoute

1. Pourquoi l'empreinte était publiée sur le site, et pas jointe au courriel. Si l'empreinte voyageait avec le fichier, celui qui modifie le fichier pourrait recalculer l'empreinte et remplacer les deux : la vérification passerait sans rien signaler. L'empreinte de référence n'a de valeur que si elle vient d'un canal que l'attaquant ne contrôle pas.

2. Ce que la signature prouve en plus. L'empreinte prouve que le document n'a pas changé par rapport à une référence — mais n'importe qui peut calculer une empreinte. La signature ne peut être produite qu'avec un secret détenu par une seule personne : elle atteste donc aussi de l'**origine**.

3. Retour sur la fausse facture. Le client aurait pu vérifier que la facture portait une signature valide de Soft-Tech. La fausse facture n'en aurait eu aucune — l'escroc ne détenant pas le secret de Soft-Tech. C'est la réponse à

la troisième question de la séquence, et elle boucle avec la première : ce qui avait été attaqué, c'était la confiance attachée au nom. La signature est ce qui permet d'attacher cette confiance à autre chose qu'à une apparence.